# Спецификация API v1 планировщика отпусков

| Параметр | Значение |
|---|---|
| Документ | Спецификация API v1 (документ 2 комплекта) |
| Версия | 1.0 |
| Дата | 27.10.2026 |
| Статус | На согласование |
| Контракт | `contracts/openapi-vacation-api-v1.yaml` — единственный источник истины по методам и схемам |

## 1. Назначение и главное правило

Документ описывает протокол взаимодействия клиента и сервера этапа 1. Формальный контракт — OpenAPI-файл; этот документ задаёт правила, которые нельзя выразить в схеме: права, семантику переходов состояний, каталог ошибок, совместимость.

**Главное правило:** сервер не доверяет клиенту. Любое ограничение, которое клиент проверяет для удобства пользователя, сервер проверяет повторно как обязательное.

## 2. Терминология

| Термин | Значение |
|---|---|
| Автор | Сотрудник, создавший заявку |
| Согласующий | Руководитель автора по полю `manager` (вверх по оргструктуре — см. В3 документа 1) либо администратор |
| Entitlement | `plannedDays + carryOver` на год |
| Перенос | Заявка на изменение дат одобренного отпуска ( `changeFrom` хранит прежние даты) |
| Запрос на удаление | Заявка с `pendingDeletion=true` на удаление одобренного отпуска |

## 3. Общие правила протокола

1. Базовый префикс `/api/v1` ; JSON в теле; даты — `YYYY-MM-DD` ; метки времени — RFC 3339 UTC.
2. Аутентификация: `Authorization: Bearer <access JWT>` ; refresh — httpOnly-cookie `vp_refresh` (SameSite=Strict, Path=/api/v1/auth).
3. Идемпотентность: `POST /auth/login` , approve/reject повторным вызовом возвращают текущее состояние (200), а не дублируют эффект.
4. Пагинация: `page` (от 1), `per_page` (1–200, по умолчанию 50); ответ — `{ items, meta: { page, perPage, total } }` .
5. Частичные обновления: `PATCH` с `minProperties: 1` ; неизвестные поля игнорируются.
6. Конфликт изменений: если сущность изменилась с момента чтения, сервер отвечает 409 `stale-state` (клиент передаёт `If-Unmodified-Since` с `updatedAt` для заявок).
7. Лимиты частоты: 429 `rate-limited` с заголовком `Retry-After` .

## 4. Аутентификация

| Метод | Описание |
|---|---|
| `POST /auth/login` | Вход: `login` , `password` → `accessToken` (15 мин) + refresh-cookie (30 дней, ротация при каждом обновлении) |
| `POST /auth/logout` | Инвалидация refresh |
| `GET /auth/me` | Профиль + вычисленные права: список подчинённых, isAdmin, manageDirectories |

Ошибки входа — единый 401 `auth/invalid-credentials` (не раскрывает, что именно неверно). Учёт: 10 попыток/мин с адреса → 429.

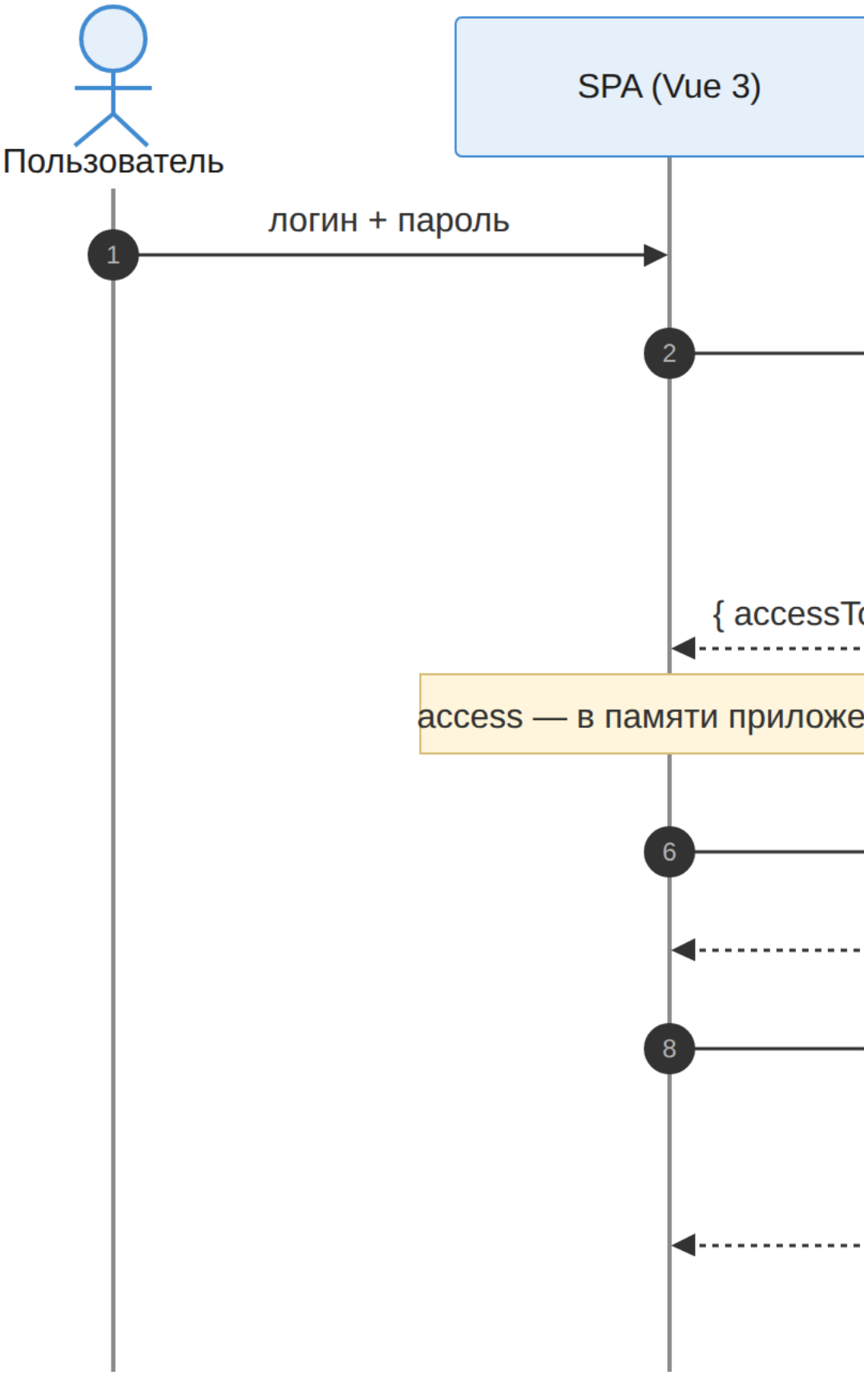
## 5. Сводная таблица методов

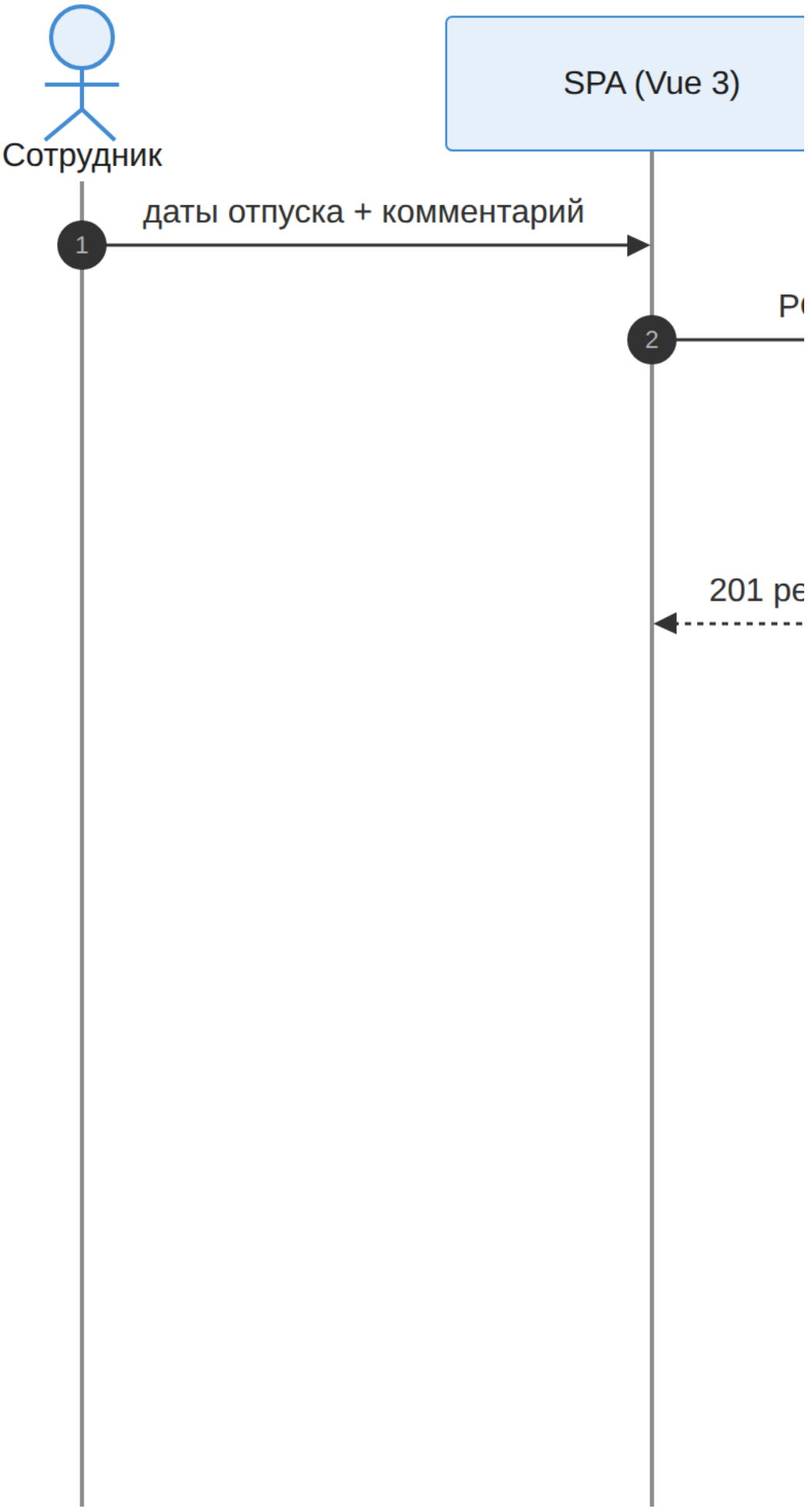
Полные схемы — в контракте. Ниже — семантика и права (У — условные права: свой профиль/подчинённые).

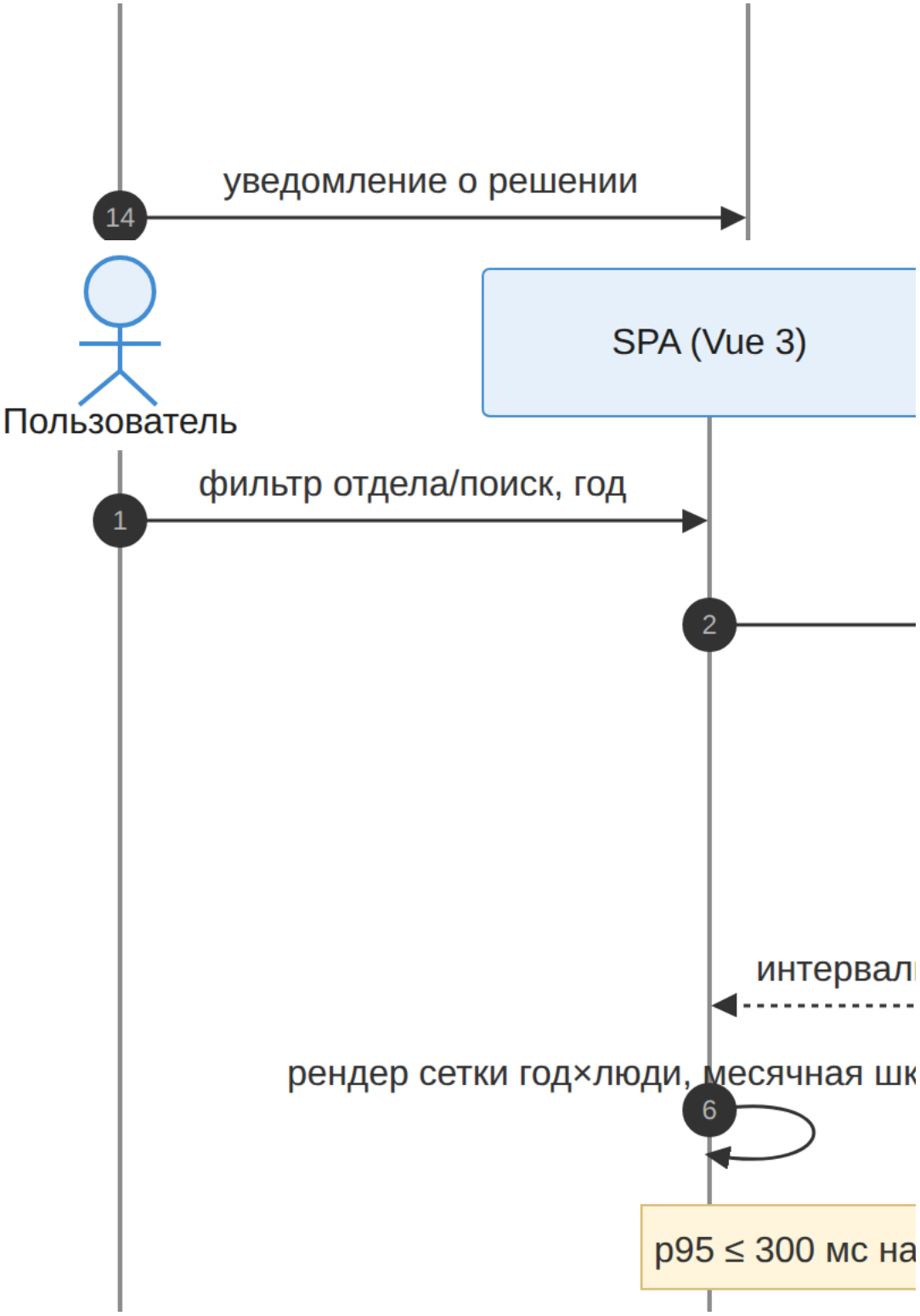
| Метод | Право | Семантика |
|---|---|---|
| GET /employees | аутентифицирован | Каталог с фильтрами и пагинацией |
| POST /employees | администратор | Создание; логин/пароль генерируются, если не заданы |
| GET/PATCH/DELETE /employees/{id} | У / админ | Карточка, изменение, увольнение |
| PUT /employees/{id}/password | У (со старым) / админ | Смена пароля; инвалидация refresh |
| GET /employees/{id}/balance | У / админ | Баланс года с разбивкой |
| PUT /employees/{id}/work-pattern | У / админ | Недельный шаблон режимов |
| PUT /employees/{id}/work-overrides | У / админ | Переопределение на дату |
| GET /vacation-requests | аутентифицирован | `scope=mine\|subordinates\|all` (all — админ) |
| POST /vacation-requests | У / за подчинённого | Создание; за подчинённого — сразу approved |
| PATCH /vacation-requests/{id} | автор / админ | Правка pending; approved → заявка-перенос |
| DELETE /vacation-requests/{id} | автор / админ | Отмена pending; approved → запрос на удаление |

| Метод | Право | Семантика |
|---|---|---|
| POST /vacation-requests/{id}/approve | согласующий | Одобрение (в т.ч. переноса и удаления) |
| POST /vacation-requests/{id}/reject | согласующий | Отклонение, комментарий обязателен |
| GET /schedule | аутентифицирован | Интервалы за период + конфликты |
| GET/POST /departments, PATCH/DELETE /departments/{name} | чтение: все; изменение: админ | Справочник отделов |
| GET/POST /projects, PATCH/DELETE /projects/{id} | чтение: все; изменение: админ | Справочник проектов |
| GET/POST /groups, PATCH/DELETE /groups/{id} | аутентифицирован | Личные группы фильтров |
| GET /settings; PATCH /settings | чтение: все; изменение: админ | Настройки организации |
| GET /calendar/holidays?year | публичный | Производственный календарь |
| GET /notifications; POST /notifications/{id}/read | аутентифицирован | Центр уведомлений |
| GET /audit-events | администратор | Журнал изменений |
| GET /reports/vacations | админ / руководитель | XLSX за период |

## 5a. Сценарии взаимодействия (sequence)


Пользователь
SPA (Vue 3)
логин + пароль
1
2
{ accessT
access — в памяти приложе
6
8


Сотрудник
SPA (Vue 3)
даты отпуска + комментарий
1
2
201 ре




### 6. Жизненный цикл заявки через API

1. `POST /vacation-requests` → 201 `pending` (или сразу `approved` при создании за подчинённого/админом). Пересечение периодов → 409 `overlapping-request`. Сверх лимита → 409 `limit-exceeded`.
2. Автор: `PATCH` меняет даты/комментарий (только `pending`); `DELETE` отменяет (`pending` → `cancelled`) либо ставит запрос на удаление (`approved` → `pending` + `pendingDeletion`).
3. Согласующий: `POST …/approve` → `approved` (для переноса — новые даты вступают в силу; для удаления — заявка исчезает, событие остаётся в аудите); `POST …/reject` → `rejected` (для переноса — даты откатываются к `changeFrom`).
4. Каждый переход пишет `history[]` в заявке и `AuditEvent`.

### 7. Каталог ошибок (RFC 9457)

`type` — URI-идентификатор `https://vacation.planner/problems/<code>`; в таблице — `<code>`.

| Код | HTTP | Когда |
|---|---|---|
| `auth/invalid-credentials` | 401 | Неверный логин/пароль |
| `auth/token-expired` | 401 | Access-токен истёк (клиент молча обновляет) |
| `auth/forbidden` | 403 | Недостаточно прав |
| `validation/invalid-field` | 400 | Не прошла схема запроса |
| `validation/bad-date-range` | 400 | `start > end`, даты в прошлом |
| `not-found` | 404 | Сущность не существует |
| `overlapping-request` | 409 | Пересечение периодов того же сотрудника |
| `limit-exceeded` | 409 | Баланс исчерпан (если политика жёсткая) |
| `stale-state` | 409 | Сущность изменилась (If-Unmodified-Since) |
| `last-admin` | 409 | Попытка удалить/разжаловать последнего администратора |
| `department-not-empty` | 409 | Удаление отдела с сотрудниками |
| `rate-limited` | 429 | Превышен лимит частоты |

Новые коды добавляются только в этот каталог и в контракт одновременно.

## 8. Матрица прав

| Действие | Сотрудник | Руководитель | Администратор |
|---|---|---|---|
| Читать график организации | да | да | да |
| Создавать заявку за себя | да | да | да |
| Создавать заявку за подчинённого | — | да (авто-approve) | да (авто-approve) |
| Согласовывать | — | подчинённые | все |
| Менять справочники | — | — | да |
| Менять настройки организации | — | — | да |
| Менять чужой профиль | — | — | да |
| Читать аудит | — | — | да |
| Выгрузки XLSX | свои | отдел/проект | организация |

## 9. Версионирование и совместимость

1. Версия — в префиксе пути. Несовместимые изменения → `/api/v2` со сосуществованием ≥ 6 месяцев.
2. Добавляющие изменения (новые поля, эндпоинты, значения enum в конце) — минорные, в рамках v1.
3. Клиент обязан игнорировать неизвестные поля и заголовки.
4. Контракт проверяется CI на каждом PR (`npm run contract:check`); диф контракта обязателен в описании PR.

## 10. Чек-лист реализации эндпоинта

- [ ] Метод описан в контракте с operationId, схемами и примерами.
- [ ] Вход валидируется схемой из контракта (ajv).
- [ ] Право проверено middleware до контроллера.
- [ ] Ошибки — только из каталога раздела 7.
- [ ] Изменение данных и аудит — в одной транзакции.
- [ ] Тесты: успех, каждая ошибка каталога, права (403), пагинация (для списков).
- [ ] Обновлены документ 5 (тексты ошибок) и CHANGELOG.